TECHNICAL REPORT

Permission-Based Security Testing Plan

A structured, low-impact methodology for authorised web application security testing.

Author	Surya Singh Chauhan
Intern ID	2418
Organisation	RedKross Research Foundation
Assignment	Security Testing Plan
Report date	20 October 2026
Submission deadline	25 October 2026
Version	1.0

Important status note: This document describes a testing plan and candidate test register. No live or local target was tested during preparation; no pass, fail, or vulnerability discovery is claimed.

Prepared for review and controlled execution only after target details and written authorisation are completed.

Executive summary

This report presents a repeatable plan for permission-based web application security testing. It defines the need for written authorisation, a clear scope and exclusions, low-impact checks, safe evidence handling, and findings that include practical remediation guidance.

The deliverable is a documented methodology and test-case register—not a report of executed security tests. The target application and environment have not yet been specified or tested. All candidate cases remain **Not Run** at this stage.

12	0	0
candidate test cases	tests executed	vulnerabilities confirmed

Report at a glance

The work product includes the testing plan, scope and authorisation template, 12-case candidate register, execution log, finding-reporting template, evidence-handling guide, workflow diagram, and a video explanation script.

Guiding principle: conduct testing only against a local lab or an explicitly authorised target. Metrics and conclusions must be based on genuine execution records.

1. Objective and background

The objective is to help the tester and system owner agree what may be tested, how tests will be conducted, how evidence will be protected, and how observations will be reported. The plan is intended for a local lab or explicitly authorised target.

Background research

The report uses the following references as guidance, without claiming formal compliance or certification:

NIST SP 800-115 — guidance for planning and conducting technical security assessments and analysing results.

OWASP Web Security Testing Guide — structured web application testing categories and reporting guidance.

OWASP Juice Shop — an intentionally insecure training application that may be used as a self-managed lab.

The project is intentionally limited to safe, non-destructive checks suitable for a student project.

2. Methodology and workflow

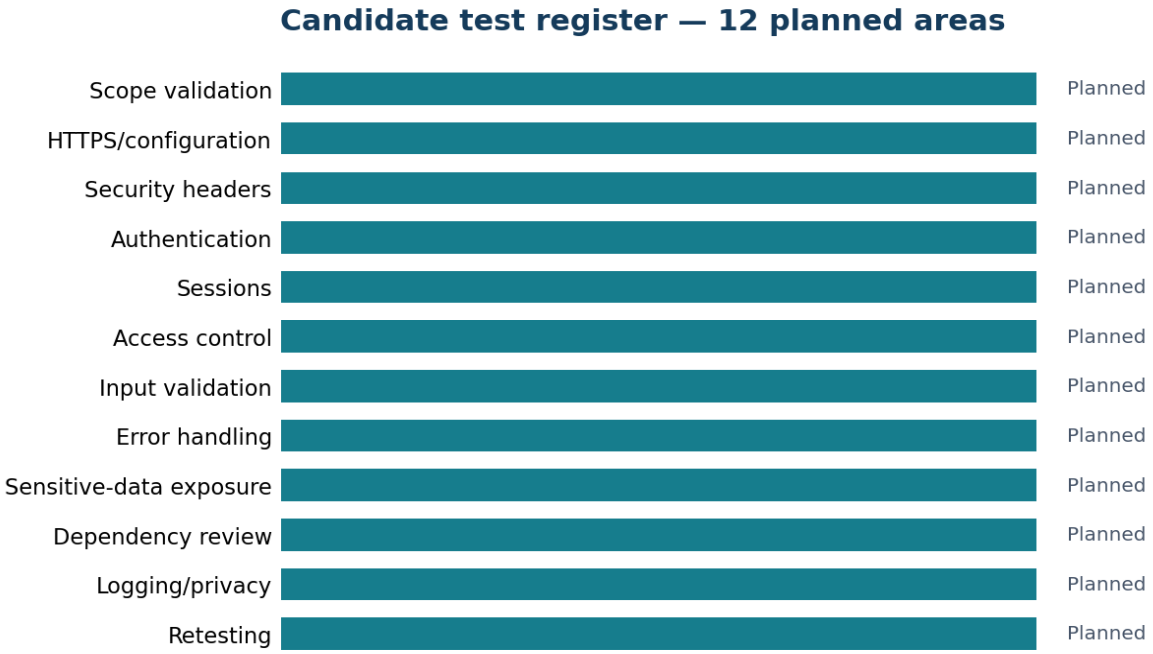
The design workflow progresses from preparation and scope validation through baseline checks, testing, observation, analysis, reporting, closure, and retesting. Execution must stop if authorisation or scope conditions are not satisfied.



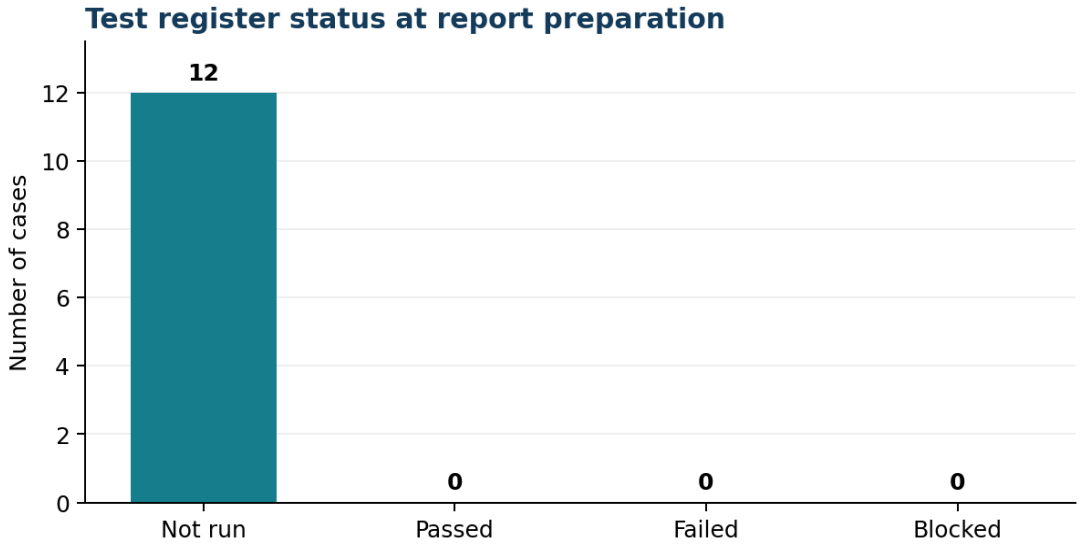
Workflow stages are planned activities, not evidence that testing has already occurred.

3. Candidate test coverage

The candidate register is designed to cover the following areas. The list describes planned coverage only; it does not indicate that any area has been tested or passed.



Test register status



The status chart reflects the report's stated preparation status: 12 candidate cases are Not Run; none is marked passed or failed, and no test execution is reported. This is a status summary, not a security outcome.

4. Tools, evidence, and deliverables

Tools and technologies

Tool / format	Purpose in this project
Markdown	Test plan, report, and reusable templates.
CSV	Structured test-case register for spreadsheet review.
SVG	Workflow diagram.
Browser and developer tools	May support low-impact observations during future authorised execution.
OWASP Juice Shop	Optional local training target if the intern chooses to set it up.

No security scanner or exploit tool was run to generate this package.

Deliverables

- Structured security testing plan
- Scope and authorisation template
- 12-case candidate test register with objective, method, expected secure behaviour, risk, and status fields
- Test execution log template
- Security finding/reporting template
- Evidence-handling guide
- Workflow diagram
- Technical report and video explanation script

Evidence handling should preserve only necessary artefacts, redact sensitive information, and keep evidence private. Reports should contain clear observations and actionable remediation guidance.

5. Evaluation approach

When testing is carried out with approval, record the following from actual execution records:

- Planned, run, blocked, and not-run cases
- Findings by severity and confidence
- Evidence completeness and redaction
- Finding owner and actionable remediation
- Retest status for fixes
- Scope deviations or stop events

Numerical testing results are intentionally not reported here because execution has not occurred. The target application and environment are unspecified; the register is a baseline checklist rather than exhaustive coverage. Manual checks may miss issues or produce false positives.

6. Recommendations

1. Select a local training application or obtain written approval for a specific target.
2. Complete and sign the scope/authorisation form before any test execution.
3. Confirm a dedicated test window, synthetic accounts, backups where appropriate, and emergency contacts.
4. Run only relevant low-impact cases and record actual observations.
5. Review findings with the system owner and prioritise fixes by impact and context.
6. Retest only with authorisation and preserve a clear audit trail.
7. Keep sensitive evidence private and publish only redacted, non-sensitive artefacts.
8. Replace the video placeholder in the README with a real, accessible video link before submission.

7. Conclusion

The project provides a structured foundation for safe, permission-based web application security testing. Its value is the connection between written scope, controlled testing, evidence handling, and practical reporting. The plan is ready for review and controlled execution after target and authorisation details are completed. Actual testing outcomes remain unverified and must be recorded only after tests are genuinely performed.

References

1. National Institute of Standards and Technology (NIST). *Technical Guide to Information Security Testing and Assessment*, SP 800-115.
https://csrc.nist.gov/pubs/sp/800/115/final

2. OWASP Foundation. *Web Security Testing Guide — Stable*.
https://owasp.org/www-project-web-security-testing-guide/stable/

3. OWASP Foundation. *OWASP Juice Shop*.
https://owasp.org/projects/juice-shop

4. OWASP Developer Guide. *Juice Shop — Vulnerable Applications for Training*.
https://devguide.owasp.org/en/07-training-education/01-vulnerable-apps/01-juice-shop/

Accessed: 20 October 2026.

Document control

Field	Value
Document	Technical Report: Permission-Based Security Testing Plan
Version	1.0
Status	Plan prepared; security testing not executed
Submission deadline	25 October 2026